



Presentación

Nombres:

Julio Cesar

Apellidos:

Hernández Tibrey

Matricula:

2025-0702

Carrera:

Seguridad informática

Materia:

Seguridad de redes

Tema:

Documentación Técnica

Docente:

Jonathan esteban rondón

Fecha:

5/06/2026

Link al video: <https://www.youtube.com/watch?v=NDWE0KuK4Mo>

Link al github: <https://github.com/Julio-Cesar-H-T/DHCP-Spoofing>

Documentación Técnica: DHCP Spoofing — Servidor DHCP Falso (Rogue DHCP)

Autor: Julio Cesar

Matrícula: 2025-0702

Fecha: 5 de junio de 2026

1. Objetivo Técnico

El propósito de este laboratorio es demostrar la viabilidad de un ataque de suplantación de infraestructura mediante la implementación de un servidor DHCP falso (Rogue DHCP). El objetivo principal es que el atacante responda a las solicitudes de concesión de red más rápido que el servidor legítimo, logrando asignar a las víctimas un *gateway* fraudulento que redirige todo su tráfico a través de la máquina atacante (estableciendo un escenario *Man-in-the-Middle* automático) y un servidor DNS bajo su control.

2. Especificaciones del Vector de Ataque

El ataque se ejecuta mediante el script en Python DHCP_Spoofing.py, el cual implementa un servidor DHCP operando en *Fast Race Mode* para ganar la condición de carrera contra el enrutador legítimo.

2.1. Parámetros de Configuración del Script

Parámetro	Valor Asignado	Descripción de la Función
Interfaz Lógica	ens4.10	Subinterfaz en Kali Linux asociada a la VLAN 10.
IP del Atacante	192.168.10.50	Dirección IP del Rogue DHCP y del <i>gateway</i> fraudulento.
Inicio del Pool	192.168.10.200	Primera dirección IPv4 que se asignará a los clientes vulnerados.
Máscara de Red	255.255.255.0	Máscara de subred entregada en la concesión.

Parámetro	Valor Asignado	Descripción de la Función
DNS Falso	8.8.8.8	Servidor de resolución de nombres entregado a la víctima.
Lease Time	600 s	Tiempo de vida de la concesión DHCP.
Volumen de Ráfaga	3	Cantidad de paquetes inyectados por cada respuesta.
Retardo Ráfaga	0.001 s	Tiempo de espera entre los paquetes de una misma ráfaga.

2.2. Requisitos Previos del Entorno Operativo

- Instalación de la biblioteca de manipulación de red scapy en el entorno Python.
- Ejecución del script con privilegios de superusuario (sudo).
- Para demostrar la efectividad del ataque por condición de carrera, el servidor DHCP legítimo (R1) debe estar operativo y con un *pool* activo.

3. Funcionamiento y Estructura del Payload

3.1. Flujo Lógico de Ejecución

1. El script inicializa un socket persistente de Capa 2 para eliminar la sobrecarga (*overhead*) por apertura individual de conexiones.
2. Se inicia un proceso de escucha pasiva (*sniffing*) sobre la interfaz ens4.10, filtrando exclusivamente el tráfico UDP en los puertos 67 y 68.
3. La recepción de un paquete legítimo desencadena la creación de un hilo de ejecución (*daemon thread*) inmediato para evitar bloqueos.
4. Lógica de respuesta según el tipo de mensaje interceptado:
 - Mensaje **DISCOVER (1)**: Construye un paquete *OFFER*, incrementa el *pool* de direcciones, asigna la operación BOOTP a 2 y emite una ráfaga de 3 respuestas con un milisegundo de separación.
 - Mensaje **REQUEST (3)**: Construye un paquete *ACK*, extrae la IP solicitada y emite una ráfaga de 3 respuestas.

5. El cliente víctima procesa la primera respuesta válida que recibe en su interfaz. Si la trama del atacante llega primero, la máquina adquiere una IP del rango 192.168.10.200+ y su tráfico se enruta hacia la IP de Kali (192.168.10.50).

3.2. Diferencial Operativo del Entorno

Parámetro Entregado	DHCP OFFER Legítimo (R1)	DHCP OFFER Falso (Kali)
IP Ofrecida (yiaddr)	192.168.10.100	192.168.10.200
Router (Gateway)	192.168.10.254	192.168.10.50
Servidor DHCP	192.168.10.254	192.168.10.50
Servidores DNS	8.8.8.8, 1.1.1.1	8.8.8.8

3.3. Técnicas de Aceleración Implementadas

El script incorpora técnicas de optimización de rendimiento: mantener el socket L2 persistente reduce la latencia operativa, el uso de hilos concurrentes permite el *sniffing* ininterrumpido, la inyección en ráfagas de 3 paquetes mitiga la pérdida de tramas y la llamada bytes(pkt) se ejecuta una sola vez para evitar la reserialización intensiva de datos.

4. Topología y Arquitectura de Red

El entorno distribuye las funciones de asignación en dos nodos en competencia dentro del mismo segmento de Capa 2.

Dispositivo	Interfaz	Modo Operativo	Asignación / IP
R1 (Servidor Legítimo)	E0/0.10	Subinterfaz L3	192.168.10.254/24
SW-1	E0/3	Access	VLAN 10 (Conexión del atacante)

Dispositivo	Interfaz	Modo Operativo	Asignación / IP
Kali (Rogue DHCP)	ens4.10	Subinterfaz L2	192.168.10.50/24
VPC-1/4 (Víctimas)	eth0	Access	Dinámica DHCP (.100 o .200)

5. Evidencias de Ejecución

(Nota para la maquetación del PDF: Insertar las siguientes capturas de pantalla en esta sección)

1. Configuración de VPC-1 ejecutando ip dhcp previo al ataque, obteniendo la concesión legítima con IP .100 y gateway .254.
2. Terminal interactiva en Kali mostrando el servidor *Rogue* activo y los registros de ráfagas [OFFER x3] y [ACK x3].
3. Configuración alterada en VPC-1, evidenciando la obtención de la IP .200+ y el gateway fraudulento apuntando a la IP .50.
4. Validación en el enrutador R1 utilizando show ip dhcp binding, comparando las direcciones MAC atendidas por el servicio legítimo frente a las interceptadas por el atacante.

6. Estrategias de Mitigación y Contra-medidas

La defensa efectiva contra servidores DHCP no autorizados requiere la implementación del protocolo de seguridad en la capa de acceso.

6.1. Implementación de DHCP Snooping

Esta función clasifica los puertos de la red en confiables (hacia servidores válidos) y no confiables (hacia usuarios). Todo mensaje DHCP OFFER originado en un puerto no confiable es descartado a nivel de hardware por el switch.

Plaintext

! Activación global del protocolo en el Switch

SW-1(config)# ip dhcp snooping

SW-1(config)# ip dhcp snooping vlan 10,20

! Establecimiento del puerto de enlace ascendente (hacia R1) como confiable

```
SW-1(config)# interface Ethernet0/0
```

```
SW-1(config-if)# ip dhcp snooping trust
```

! Aplicación de límites de tasa en los puertos de acceso de usuarios

```
SW-1(config)# interface Ethernet0/3
```

```
SW-1(config-if)# ip dhcp snooping limit rate 15
```

6.2. Auditoría del Estado de Seguridad

El administrador debe corroborar el funcionamiento de las restricciones utilizando los comandos `show ip dhcp snooping`, `show ip dhcp snooping binding` y analizando las métricas de paquetes descartados con `show ip dhcp snooping statistics`.

Evidencias

```
[sudo] password for user:
=====
DHCP Spoofing - FAST RACE MODE
=====
Interfaz   : ens4.10
GW falso   : 192.168.10.50
Pool       : 192.168.10.200 -
DNS        : 8.8.8.8
Ráfaga     : 3 paquetes por respuesta
Retardo    : 1.0 ms entre paquetes de ráfaga

[*] Abriendo socket L2 persistente...
[*] Escuchando... (Ctrl+C para salir)
```

```
VPCS> show ip
NAME       : VPCS[1]
IP/MASK    : 0.0.0.0/0
GATEWAY    : 0.0.0.0
DNS        :
MAC        : 00:50:79:66:68:13
LPORT     : 20000
RHOST:PORT : 127.0.0.1:30000
MTU        : 1500

VPCS> dhcp
DORA IP 192.168.10.200/24 GW 192.168.10.50
```

```
VPCS> clear ip
IPv4 address/mask, gateway, DNS, and DHCP cleared

VPCS> dhcp
DORA IP 192.168.10.100/24 GW 192.168.10.254
```